

CLAUDE CODE DEEP DIVE WORKSHOP

Chapter 3 - Admin Setup

개인의 도구를 조직의 플랫폼으로

Update : 2026.09 / Claude Code v2.1 최신 채널 기준, 공식 문서 code.claude.com/docs 반영

Choi, WooHyung

Prin. Solutions Architect

AWS Korea

whchoi@amazon.com

Chapter 3 Agenda

9 Parts / 112 Slides

PART 01	배포 전략	설치 채널, 미러, 버전 통제, 롤아웃 / 13p
PART 02	공급자와 자격증명	Bedrock, Vertex, Foundry, 회전과 볼트 / 15p
PART 03	Claude apps gateway	SSO 게이트웨이, 모델 라우팅, 지출 한도 / 10p
PART 04	네트워크와 보안	프록시, 사내 CA, 도메인 통제, 샌드박스 / 12p
PART 05	거버넌스와 정책	managed 4채널, 강제 키, MCP 통제 / 14p
PART 06	모니터링과 비용	OTel, Analytics, 비용 귀속과 알람 / 13p
PART 07	신원, 데이터, 컴플라이언스	SSO, ZDR, CloudTrail, 규제 매핑 / 12p
PART 08	트러블슈팅	인증, 네트워크, 성능, 에스컬레이션 / 6p
PART 09	Recap & Labs	요약, 실습 3종, 실행 로드맵 / 12p

Chapter 3 Learning Objectives

본 챕터에서 달성할 학습 목표

AT THE END OF THIS CHAPTER

조직 규모의 설치와 인증 체계를 설계하고, managed settings로 정책을 강제하며, OTel과 대시보드로 사용을 관측하고, 컴플라이언스 요구에 답할 수 있습니다.

OBJ 1

배포 설계

설치 채널과 미러, 버전 통제로 대량 배포를 설계.

OBJ 2

인증 체계

공급자 선택과 SSO, 자격증명 회전 체계를 구축.

OBJ 3

정책 강제

managed settings 4채널과 강제 키로 거버넌스 확립.

OBJ 4

관측과 대응

OTel, 비용 귀속, 감사 로그로 운영을 가시화.

9 Parts

구조화된 학습 경로

3 Labs

Chapter 3 실습 랩

4 채널

managed 배포 경로

~3h + 1h

강의와 실습 시간

Admin이 마주하는 도전

개인 도구와 조직 플랫폼의 간극

개발자의 세계 (Chapter 1, 2)

- 원라이너 설치, 개인 구독 로그인
- 내 settings.json과 내 에이전트
- 자유로운 도구와 웹 접근
- 비용은 내 플랜 한도

관리자의 질문 (Chapter 3)

- 500명에게 어떻게 배포하고 갱신하나
- 키를 나눠주지 않고 인증하려면
- 금지 명령과 도메인을 어떻게 강제하나
- 누가 얼마나 쓰는지, 감사는 어떻게

Scale

수백 명 규모

No keys

키 미배포 원칙

Enforce

정책은 강제로

Audit

증적 가능한 운영

03

Admin Setup

배포, 인증, 거버넌스, 관측의 조직 설계

CHAPTER 03 / PART 01

배포 전략

500대에 설치하고 갱신하는 법

1. 설치 채널 4계열과 조직 관점 선택
2. 사내 미러와 Artifactory 운영
3. 버전 통제: 채널 고정과 minimumVersion
4. 점진 롤아웃과 에어갭 대응

설치 채널 4계열 / 조직 관점

무엇으로 500대를 깔 것인가

Native 스크립트

claude.ai/install.sh, 단일 바이너리, 자동 갱신

표준 권장, MDM 스크립트화

OS 패키지 저장소

apt, dnf, apk 공식 저장소, GPG 서명

리눅스 서버 플릿

패키지 매니저

Homebrew cask, WinGet

개발자 셀프서비스

컨테이너

표준 이미지, devcontainer

CI 러너, 통제 환경

npm (레거시)

Node 의존, 신규 배포 비권장

기존 파이프라인 호환용

Linux 플릿 / 공식 저장소 등록

GPG 검증 포함 표준 절차

```
fleet provisioning (apt)

$ sudo install -d -m 0755 /etc/apt/keyrings
$ sudo curl -fsSL https://downloads.claude.ai/keys/claude-code.asc \
  -o /etc/apt/keyrings/claude-code.asc
$ gpg --show-keys /etc/apt/keyrings/claude-code.asc
# 지문 대조: 31DD DE24 DDFA B679 F42D 7BD2 BAA9 29FF 1A7E CACE

$ echo "deb [signed-by=/etc/apt/keyrings/claude-code.asc] \
  https://downloads.claude.ai/claude-code/apt/stable stable main" \
  | sudo tee /etc/apt/sources.list.d/claude-code.list
$ sudo apt update && sudo apt install claude-code
```

GPG 지문

신뢰 전 필수 대조

stable

플릿 기본 채널

Ansible

이 절차의 코드화

dnf/apk

동일 패턴 제공

사내 미러 운영

Artifactory, Nexus로 다운로드 경로 내재화

INTERNAL MIRROR

외부 다운로드가 막힌 망이나 대역폭, 감사 요구가 있는 조직은 공식 저장소를 사내 아티팩트 서버로 미러링합니다.

WHAT

미러 대상

apt, rpm 저장소와 native 설치 자산, 필요 시 npm 패키지.

HOW

프록시 저장소

Artifactory, Nexus의 remote repo로 상류 캐시 구성.

POINT

클라이언트 전환

sources.list와 설치 스크립트 URL을 사내 주소로 치환.

TRUST

서명 유지

GPG 검증은 그대로, 미러도 서명 파일을 함께 제공.

Remote repo

상류 캐시 방식

서명 보존

무결성 원칙

감사 로그

다운로드 이력 확보

Lab 1

실습에서 구축

Windows 대량 배포

WinGet 플릿과 레지스트리 정책

● ● ● windows fleet (PowerShell)

```
# Intune, SCCM 배포 스크립트 골격
winget install Anthropic.ClaudeCode --silent \
  --accept-package-agreements
```

```
# 관리 정책은 HKLM 레지스트리로 (Part 5 상세)
# HKLM\SOFTWARE\Policies\ClaudeCode
# 관리자 권한 필요, 번조 저항
```

```
# WSL 병행 조직
# wslInheritsWindowsSettings: true 로
# Windows 정책을 WSL까지 상속
```

Intune/SCCM

배포 채널

HKLM

정책 레지스트리

WSL 상속

정책 일원화 키

MSI 문의

대안 패키징 경로

표준 컨테이너 이미지

CI 러너와 통제 개발 환경

Dockerfile (org standard)

```
FROM ubuntu:24.04
RUN apt-get update && apt-get install -y \
    curl git ca-certificates ripgrep jq
RUN curl -fsSL https://claude.ai/install.sh | bash -s 2.1.201
ENV PATH="/root/.local/bin:${PATH}"
ENV DISABLE_AUTOUPDATER=1
COPY managed-settings.json /etc/claude-code/
WORKDIR /workspace
```

버전 고정 + 자동갱신 차단 + 정책 내장이 3원칙

버전 고정
재현 가능성

AUTOUPDATER=0..1
이미지 불변성

정책 내장
/etc/claude-code

devcontainer
개발자 배포판

버전 통제 두 다이얼

채널과 최소 버전

VERSION GOVERNANCE

autoUpdatesChannel로 갱신 속도를, minimumVersion으로 하한선을 통제합니다. 둘 다 관리 설정으로 강제할 수 있습니다.

DIAL 1

autoUpdatesChannel

stable 고정이 플릿 기본,
latest는 얼리어답터 링만.

DIAL 2

minimumVersion

보안 픽스 하한선, 미달 버전
은 강제 갱신 유도.

FREEZE

완전 고정

DISABLE_AUTOUPDATE
R=1 + 버전 지정 설치, CI
전용.

WHERE

강제 위치

managed-settings에 넣
어 개인이 못 바꾸게.

stable

플릿 채널 기본

minimumVersion

하한 강제 키

CI만 고정

완전 고정 범위

managed

정책 배포 채널

점진 롤아웃 전략

파일럿에서 전사까지 4링

RING DEPLOYMENT

링 단위로 넓히며 각 관문에서 채택 지표와 사고 여부를 확인합니다. 정책과 버전은 링별로 독립 조정합니다.

RING 0

챔피언 10명

latest 채널, 피드백 루프
구축

RING 1

파일럿 팀 50

stable, managed 정책
초판 적용

RING 2

부문 200

교육 자료 배포, 지표 관측

RING 3

전사

표준 온보딩, 지원 체계 정
착

오프라인, 에어갭 환경

외부망 없는 곳의 선택지

AIR-GAP REALITY

설치는 미러로 해결되지만 추론 트래픽은 모델 엔드포인트가 필요합니다.

완전 격리망은 클라우드 프라이빗 연결이 현실적인 답입니다.

INSTALL

설치 자산

사내 미러와 이미지 레지스트리로 완전 내재화 가능.

INFERENCE

추론 경로

Bedrock + PrivateLink 등 프라이빗 연결로 폐쇄망 대응.

POLICY

정책 배포

파일 기반 managed-settings를 형상 관리로 배포.

LIMIT

한계 인지

웹 검색 등 외부 의존 기능은 도메인 정책으로 차단 명시.

미러

설치 내재화

PrivateLink

추론 프라이빗 경로

파일 배포

정책 채널

Part 2, 4

상세 연결 파트

멀티 플랫폼 전략표

OS별 표준 조합

macOS	Native + MDM 스크립트, plist 정책	Jamf, Kandji 배포
Windows	WinGet + Intune, HKLM 정책	WSL 상속 키 병행
Linux	apt/dnf 저장소, /etc/claude-code 정책	Ansible 코드화
컨테이너	표준 이미지, 정책 내장, 갱신 차단	CI와 devcontainer
검증	전 플랫폼 /status로 정책 소스 확인	(remote/plist/HKLM/file)

사용량, 용량 예측

도입 전 산정의 기준선

SEATS

좌석 산정

활성 개발자 기준, 파일럿
실측으로 배수 보정.

TOKENS

토큰 추정

1인 1일 세션 수와 평균
규모를 파일럿에서 실측.

MODEL MIX

모델 배분

sonnet 중심, opus 비중이
비용의 지배 변수.

PEAK

피크 대비

클라우드 경로는 리전 쿼터
와 스로틀 한도 사전 확인.

파일럿 실측
추정의 근거

opus 비중
비용 지배 변수

쿼터
Bedrock 사전 확인

Part 6
관측으로 보정

배포 전 체크리스트

출발 전 확인 10항

채널, 버전

stable + minimumVersion 결정

관리 설정 초안 반영

설치 경로

플랫폼별 표준 조합 확정

MDM, Ansible 스크립트

미러

필요 여부와 서명 배포 확인

폐쇄망, 감사 요구 시

정책 파일

managed-settings 초판과 배포 채널

Part 5에서 완성

롤백

이전 버전 재설치 절차 문서화

버전 지정 설치 활용

Part 1 Recap

배포 전략 핵심 정리

KEY TAKEAWAY

설치는 플랫폼별 표준 조합으로, 갱신은 채널과 하한선 두 다이얼로, 확산은 링으로. 검증은 /status 한 줄로 통일됩니다.

핵심 정리

- 채널 4계열, npm은 레거시
- GPG 지문 대조가 신뢰의 출발
- 미러로 폐쇄망, 감사 대응
- stable + minimumVersion
- 링 롤아웃과 champion kit

다음 파트

- Part 2 공급자와 자격증명
- 공급자 결정표
- Bedrock IAM과 SSO
- 회전과 볼트 통합
- PrivateLink

CHAPTER 03 / PART 02

공급자와 자격증명

키를 나눠주지 않는 인증 설계

1. 공급자 결정표와 인증 우선순위
2. Bedrock: IAM 정책과 Identity Center SSO
3. Vertex, Foundry, Claude Platform on AWS
4. 회전, 볼트 통합, PrivateLink

공급자 결정표

공식 admin-setup 권고 기준

Teams / Enterprise	좌석제, 인프라 불필요, 기본 권장	claude.ai와 통합 관리
Claude Console	API 우선, 종량 과금	파이프라인 중심 조직
Amazon Bedrock	AWS 컴플라이언스와 과금 상속	AWS 표준 기업
Google Vertex AI	GCP 통제 상속	GCP 표준 기업
Microsoft Foundry	Azure 통제 상속	Azure 표준 기업
혼합	LLM gateway로 단일 엔드포인트	중앙 로깅 요구 시

인증 우선순위 복습

충돌 시 무엇이 이기는가 (Chapter 1)

1 CLAUDE_CODE_

USE_BEDROCK / USE_VERTEX / USE_FOUNDRY 강제 스위치

2 ANTHROPIC_API_KEY

환경변수 키, CI와 서버 자동화 경로

3 apiKeyHelper

settings의 동적 키 헬퍼 스크립트, 볼트 연동 지점

4 OAuth 토큰

setup-token 장기 토큰, claude.ai 로그인 세션

Bedrock 설정 개요

조직 표준 환경 구성

org profile (/etc/profile.d/claude.sh)

```
export CLAUDE_CODE_USE_BEDROCK=1
export AWS_REGION=ap-northeast-2
```

```
# 모델 alias는 리전 가용성에 맞춰 해석됨
# 필요 시 인퍼런스 프로파일 ID로 고정
# export ANTHROPIC_MODEL=\
#   apac.anthropic.claude-sonnet-5-v1:0
```

```
$ aws sso login --profile dev && export AWS_PROFILE=dev
$ claude # /status 로 Bedrock 활성 확인
```

USE_BEDROCK=1

강제 스위치

리전

가용성, 지연 결정

프로파일 ID

모델 고정 옵션

/status

활성 검증

Bedrock IAM 정책

최소 권한의 표준형

iam policy (claude-code-bedrock)

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "ClaudeCodeInvoke",
    "Effect": "Allow",
    "Action": ["bedrock:InvokeModel",
      "bedrock:InvokeModelWithResponseStream"],
    "Resource":
      "arn:aws:bedrock:*::foundation-model/anthropic.*"
  }]
}
```

Invoke 2종

필요 액션 전부

anthropic.*

리소스 스코프

리전 축소

와일드카드 대체 가능

Deny 조합

특정 모델 차단

Bedrock + Identity Center SSO

키 없는 인증의 전체 흐름

SSO FLOW

개발자는 브라우저 로그인만, 자격증명은 단기 토큰으로 자동 발급됩니다. 퇴사자는 IdP에서 끊는 순간 접근이 사라집니다.

STEP 1

IdP 로그인

aws sso login, 브라우저 인증

STEP 2

권한 매핑

그룹 -> Permission Set (IAM 정책)

STEP 3

단기 자격증명

STS 토큰 자동 발급, 갱신

STEP 4

Bedrock 호출

Claude Code가 SDK 체인으로 사용

Claude Platform on AWS

Anthropic 운영 API를 AWS 인증으로

FOURTH PATH

Anthropic이 운영하는 Claude API를 AWS IAM 인증과 Marketplace 과금으로 쓰는 경로입니다.
최신 기능 속도와 AWS 거버넌스를 함께 가져옵니다.

WHAT

구조

엔드포인트는 Anthropic,
인증과 과금은 AWS.

AUTH

IAM 접근 통제

역할 기반 접근, 정적 키 불
필요.

BILL

Marketplace

AWS 청구서로 통합, 조달
절차 단순화.

WHEN

선택 시점

최신 기능 우선 + AWS 과
금 유지가 동시에 필요할 때.

4th

공급자 네 번째 경로

IAM

접근 통제 측

Marketplace

과금 채널

docs 참조

[claude-platform-on-aws](#)

API Key 분배의 위험과 대안

정적 키를 사람 손에 주지 않는다

NO STATIC KEYS

키 분배는 유출, 이직, 회전의 3중 부담을 만듭니다.

사람에게는 SSO, 기계에는 볼트와 헬퍼가 원칙입니다.

정적 키 분배의 부담

1. 커밋, 로그, 채팅으로 유출 경로 다수
2. 퇴사 시 회수 불가, 전수 회전 필요
3. 누가 썼는지 귀속 불가
4. 감사 대응 시 증적 공백

대안 체계

1. 사람: SSO 단기 토큰 (Bedrock, Entra)
2. 기계: Secrets Manager + apiKeyHelper
3. CI: OIDC 페더레이션, setup-token 최소화
4. 환경변수 하드코딩 전면 금지 정책

apiKeyHelper / 볼트 통합

키가 필요하다면 동적으로

settings.json + helper

```
// ~/.claude/settings.json
{ "apiKeyHelper": "/opt/claude/get-key.sh",
  "env": { "CLAUDE_CODE_API_KEY_HELPER_TTL_MS":
    "300000" } }
```

```
#!/bin/bash # /opt/claude/get-key.sh
aws secretsmanager get-secret-value \
  --secret-id claude/team-api-key \
  --query SecretString --output text
```

TTL마다 재호출, 회전이 클라이언트에 자동 반영

Helper

동적 키 공급

TTL 5분

갱신 주기 예시

Secrets Mgr

중앙 저장소

자동 반영

회전 무중단

자격증명 회전 체계

회전이 무사고가 되는 절차

STEP 1

이중화

신 키 발급, 볼트에 병행 저장

STEP 2

전환

볼트 포인터를 신 키로 스위치

STEP 3

관찰

TTL 경과 후 구 키 호출 0 확인

STEP 4

폐기

구 키 비활성화, 감사 기록

SSO 경로는 회전 자체가 불필요, 이 절차는 헬퍼 기반 키에만 해당

무중단

이중화 원칙

TTL 기준

전환 관찰 시간

분기 주기

정기 회전 권장

SSO 예외

회전 불필요 경로

PrivateLink와 VPC Endpoint

추론 트래픽의 프라이빗 경로

PRIVATE INFERENCE

Bedrock 호출을 인터넷 없이 VPC 내부에서 처리합니다.

폐쇄망 요건과 데이터 경로 통제 요구의 표준 답안입니다.

SETUP

엔드포인트

bedrock-runtime
인터페이스 엔드포인트 생성.

DNS

사설 해석

Private DNS 활성화로
SDK 무수정 전환.

CTRL

정책 결합

엔드포인트 정책으로 호출
가능 모델, 주체 제한.

AUDIT

경로 증명

VPC Flow Logs로 트래픽
경로 증적.

bedrock-runtime

대상 서비스

무수정

Private DNS 효과

EP 정책

추가 통제 계층

Flow Logs

경로 증적

자격증명 의사결정

주체별 표준 경로 확정

개발자 (일상)

Bedrock + Identity Center SSO

정적 키 0

CI 파이프라인

OIDC 역할 인수, 필요 시 setup-token

장기 시크릿 최소화

공유 서비스

Secrets Manager + apiKeyHelper

TTL 회전 자동화

폐쇄망

PrivateLink + SSO

경로와 인증 동시 해결

예외 승인

기간 한정, 사유 기록, 자동 만료

감사 대장 유지

Part 2 Recap

공급자와 자격증명 핵심 정리

KEY TAKEAWAY

사람에게는 SSO, 기계에는 볼트, CI에는 OIDC.

정적 키가 없는 조직이 회전과 오프보딩의 비용을 구조적으로 없앱니다.

핵심 정리

1. 결정표: 좌석제 기본, AWS는 Bedrock
2. 강제 스위치가 인증 최상위
3. IAM 최소 권한 + Permission Set
4. helper + TTL로 회전 자동화
5. PrivateLink로 폐쇄망 대응

다음 파트

1. Part 3 Claude apps gateway
2. 자체 호스팅 SSO 게이트웨이
3. 그룹별 모델 라우팅
4. 지출 한도 Admin API
5. OTLP 텔레메트리

CHAPTER 03 / PART 03

Claude apps gateway

자체 호스팅 SSO 게이트웨이

1. 왜 게이트웨이인가: 클라우드 경로의 빈 조각
2. gateway.yaml 아키텍처와 SSO 사인인
3. 그룹별 모델 라우팅과 지출 한도 API
4. 배포, 운영, OTLP 텔레메트리

왜 게이트웨이인가

클라우드 경로에 남던 빈 조각

THE MISSING PIECE

Bedrock 직결은 인증과 과금을 상속하지만, 조직 로그인 경험과 그룹별 모델 통제, 개인 지출 한도는 비어 있었습니다. 게이트웨이가 그 조각을 채웁니다.

Bedrock 직결에서 비던 것

1. 개발자별 지출 한도 실시간 강제
2. IdP 그룹별 모델 접근 차등
3. 조직 표준 로그인 UX
4. 요청 단위 중앙 텔레메트리

apps gateway가 채우는 것

1. 일, 주, 월 한도를 Admin API로 설정, 즉시 강제
2. 그룹 -> 모델 라우팅 규칙
3. OIDC SSO 사인인 플로우
4. OTLP로 전 요청 관측

아키텍처 / gateway.yaml 구성

요청이 지나가는 다섯 층

Listener + TLS

수신 포트와 인증서, 조직 도메인으로 서비스

OIDC + Session

IdP 연동 사인인, 세션 저장은 Postgres

Policy

managed 정책, 그룹 매핑, 지출 한도 판정

Model Routing

요청 모델을 그룹 규칙에 따라 허용, 치환

Upstream

Bedrock, Agent Platform, Foundry로 전달

개발자 경험 / SSO 사인인

키도 프로파일도 없는 로그인

developer flow

```
# 클라이언트는 게이트웨이만 바라봄
export ANTHROPIC_BASE_URL=https://claude-gw.corp.example
```

```
$ claude
```

```
# 브라우저가 열리고 조직 IdP 로그인 (OIDC)
# 세션 수립, 이후 요청은 게이트웨이가 상류 인증 대행
```

```
> /status
```

```
# 공급자: gateway 경유, 그룹과 허용 모델 확인
```

```
# AWS 프로파일, 정적 키, 리전 설정이 전부 사라짐
```

BASE_URL

클라이언트 설정 전부

OIDC

조직 IdP 로그인

대행

상류 인증은 게이트웨이

0 keys

개발자 손의 키

그룹별 모델 라우팅

IdP 그룹이 모델 접근을 결정

gateway.yaml (routing)

```
routing:
  groups:
    - match: "eng-platform"
      allowedModels: [opus, sonnet, haiku]
    - match: "eng-default"
      allowedModels: [sonnet, haiku]
      rewrite: { opus: sonnet } # 요청 치환
    - match: "contractors"
      allowedModels: [haiku]

# IdP 그룹 클레임 기준, 위반 요청은 거부 또는 치환
```

그룹 클레임

판정 근거

allow 목록

모델 차등

rewrite

상위 요청 하향 치환

중앙 1곳

규칙 관리 지점

지출 한도 / Admin API

개발자별 일, 주, 월 캡을 실시간 강제

● ● ● spend limits (admin api)

한도 설정

```
$ curl -X PUT https://claude-gw.corp.example/admin/limits \  
-H "Authorization: Bearer $ADMIN_TOKEN" \  
-d '{ "subject": "user:jdoe",  
      "period": "month", "usd": 300 }'
```

동작

- # 게이트웨이가 요청마다 누적 지출을 판정
- # 한도 도달 시 요청 거부, 사용자에게 사유 표시
- # 그룹 기본값 + 개인 예외의 2단 구성 가능

day/week/month

기간 3종

실시간

요청 단위 강제

PUT /limits

Admin API

그룹+개인

2단 구성

배포와 운영

Kubernetes, Cloud Run 표준 경로

DEPLOY AND OPERATE

컨테이너 하나와 Postgres가 전부입니다.

IdP 등록, 시크릿, 헬스체크, 업그레이드의 운영 절차가 공식 문서로 제공됩니다.

STACK

구성 요소

게이트웨이 컨테이너 +
Postgres 세션 저장소.

IDP

사전 등록

OIDC 클라이언트 등록, 리
다이렉트 URI 지정.

OPS

운영 루틴

헬스체크 엔드포인트, 시크
릿 회전, 무중단 업그레이드.

HA

가용성

무상태 수평 확장, 세션은
Postgres가 담당.

K8s/CloudRun

표준 타깃

Postgres

세션 스토어

헬스체크

운영 관문

수평 확장

무상태 설계

OTLP 텔레메트리

요청 단위 중앙 관측

EXPORT

OTLP 송출

게이트웨이가 전 요청의
메트릭, 트레이스를 표준
송출.

DIMS

차원

사용자, 그룹, 모델, 토큰,
판정 결과 태그.

SINK

수집처

CloudWatch, Datadog
등 OTEL 호환 어디든.

MERGE

클라이언트 결합

Part 6의 클라이언트
OTel과 상호 보완.

OTLP

표준 프로토콜

요청 단위

집계 해상도

판정 태그

한도, 라우팅 결과

Part 6

관측 파트 연결

apps gateway vs 일반 LLM gateway

무엇이 다른가

PURPOSE-BUILT

일반 LLM 게이트웨이는 범용 프록시, apps gateway는 Claude Code 조직 운영에 특화된 완제품입니다.

일반 LLM gateway (LiteLLM 등)

1. 다중 벤더 추상화가 목적
2. Claude Code 정책 모델 미인지
3. 한도, 라우팅을 직접 구현
4. 범용 프록시 유지보수 부담

Claude apps gateway

1. Claude Code 전용 설계
2. managed 정책과 자연 결합
3. SSO, 라우팅, 한도가 내장 완제품
4. 공식 배포, 운영 문서 제공

Part 3 Recap

apps gateway 핵심 정리

KEY TAKEAWAY

주소 하나, 로그인 한 번.

그룹별 모델과 개인별 한도, 요청 단위 관측이 자체 호스팅 게이트웨이 하나로 조직에 들어옵니다.

핵심 정리

1. 빈 조각 4: 한도, 차등, UX, 관측
2. 5층: TLS, OIDC, 정책, 라우팅, 상류
3. BASE_URL 하나로 클라이언트 완성
4. 지출 한도 Admin API 실시간 강제
5. OTLP 중앙 텔레메트리

다음 파트

1. Part 4 네트워크와 보안
2. 프록시와 사내 CA
3. 필수 도메인 화이트리스트
4. 샌드박스 네트워크 통제
5. DLP 혹은

CHAPTER 03 / PART 04

네트워크와 보안

사내망에서 안전하게 통과시키기

1. 필수 도메인과 프록시, 사내 CA
2. sandbox 네트워크로 curl 우회 갭 봉쇄
3. VPN, ZTNA 환경 통합
4. DLP 혹은 사내 MCP 통합

필수 아웃바운드 도메인

방화벽 화이트리스트 기준선

api.anthropic.com	추론 API (Anthropic 직결 경로)	Bedrock 경로는 불필요
claude.ai	구독 로그인, 서버 관리 설정 수신	Teams, Enterprise
downloads.claude.ai	설치 자산, 패키지 저장소, 자동 갱신	미러 운영 시 대체
statsig 계열	기능 플래그 수신	차단 시 기본값 동작
sentry 계열	오류 리포트 송신	차단 가능, 진단 저하
클라우드 엔드포인트	bedrock-runtime.<region>.amazonaws.com 등	PrivateLink로 대체 가능

사내 프록시 통과

표준 환경변수 세 개

proxy env

```
export HTTPS_PROXY=http://proxy.corp.example:8080
export HTTP_PROXY=http://proxy.corp.example:8080
export NO_PROXY=localhost,127.0.0.1,.corp.example

# 조직 배포: /etc/profile.d 또는 MDM 프로파일로
# NO_PROXY에 사내 MCP, 게이트웨이 도메인 포함

$ claude # /status 와 첫 응답으로 경로 확인
# 실패 시 진단: curl -v https://api.anthropic.com/ 로
# 프록시 계층과 TLS 계층을 분리 확인
```

HTTPS_PROXY

핵심 변수

NO_PROXY

사내 예외 목록

profile.d

조직 배포 위치

curl -v

분리 진단 도구

인증 프록시 대응

Basic, NTLM, Kerberos 환경

AUTH PROXY

자격증명을 요구하는 프록시는 URL 삽입 대신 로컬 중계를 세우는 것이 안전합니다.

평문 자격증명이 환경변수에 남지 않습니다.

AVOID

URL 삽입 지양

`http://user:pass@proxy` 형태는 유출 면적 확대.

RELAY

로컬 중계

Px, Cntlm 등으로 NTLM, Kerberos를 로컬에서 처리.

POINT

클라이언트 설정

HTTPS_PROXY는 localhost 중계 포트만 가리킴.

ZTNA

현대 대안

가능하면 인증 프록시 자체를 ZTNA로 대체 권고.

No creds in URL

원칙

Px/Cntlm

중계 도구

localhost

클라이언트 관점

ZTNA

구조적 대안

사내 CA 인증서

TLS 검사 장비 뒤에서

corporate CA

```
# 증상: SELF_SIGNED_CERT_IN_CHAIN, TLS 오류

# 해법: 사내 루트 CA를 신뢰 체인에 추가
export NODE_EXTRA_CA_CERTS=/etc/ssl/corp/corp-root-ca.pem

# OS 신뢰 저장소 병행 등록 (curl 등 다른 도구용)
# Debian: /usr/local/share/ca-certificates + update-ca-certificates
# RHEL: /etc/pki/ca-trust/source/anchors + update-ca-trust

# 금지: NODE_TLS_REJECT_UNAUTHORIZED=0 (검증 무력화)
```

EXTRA_CA_CERTS

핵심 변수

PEM 번들

형식 요건

OS 저장소

병행 등록

검증 해제 금지

보안 원칙

sandbox 네트워크 / curl 갭 봉쇄

권한 규칙이 못 막는 총을 OS가 막는다

```
managed-settings.json (sandbox)

// 문제: WebFetch를 deny해도 Bash가 허용이면
//       curl, wget으로 임의 URL 접근 가능

{
  "sandbox": {
    "enabled": true,
    "network": {
      "allowedDomains": [
        "api.anthropic.com", "*.corp.example",
        "github.corp.example"
      ] } } }
```

OS 레벨
강제 계층

allowedDomains
아웃바운드 허용 목록

curl/wget
봉쇄 대상 갭

admin-setup
공식 권고 근거

VPN, ZTNA 환경 통합

터널과 정책 프록시 위에서

VPN 환경 점검

1. 스플릿 터널 시 API 도메인 경로 확인
2. MTU 문제로 스트리밍 끊김 진단
3. DNS가 사내 리졸버 경유인지 확인
4. 터널 밖 예외는 NO_PROXY 정합성

ZTNA 환경 점검

1. 앱 단위 정책에 클라이언트 등록
2. 도메인 허용을 커넥터 정책에 반영
3. 디바이스 포스처 요건과 CLI 호환 확인
4. 게이트웨이 경유 시 BASE_URL만 내부

DLP 혹 / 유출 패턴 차단

나가는 내용을 검사하는 마지막 관문

./scripts/dlp-guard.sh (PreToolUse)

```
#!/bin/bash
INPUT=$(cat)
CMD=$(echo "$INPUT" | jq -r '.tool_input.command // empty')

# 외부 전송 명령 + 민감 패턴 결합 시 차단
if echo "$CMD" | grep -qE 'curl|wget|nc|scp' &&
  echo "$CMD" | grep -qE 'sk-ant-[AKIA[0-9A-Z]{16}]BEGIN.*PRIVATE KEY'; then
  echo "Blocked by DLP: credential exfil pattern" >&2
  exit 2
fi
exit 0
```

PreToolUse

차단 지점

전송+민감

결합 판정

exit 2

차단, 사유 회신

managed 배포

조직 강제 경로

사내 MCP 서버 통합

내부 시스템을 도구로

INTERNAL MCP

사내 위키, 티켓, 배포 시스템을 MCP로 노출하면 Claude Code가 조직 컨텍스트를 갖게 됩니다.
네트워크와 정책 두 층의 준비가 필요합니다.

NET

경로 확보

NO_PROXY와 sandbox
allowedDomains에 내부
도메인 등록.

AUTH

인증 방식

OAuth 지원 서버 권장, 토큰은
볼트 헬퍼로.

POLICY

허용 통제

allowedMcpServers로 승인
서버만 (Part 5).

SCOPE

노출 최소화

서브에이전트 mcpServers
로 필요한 곳에만.

내부 도메인

네트워크 준비

OAuth

권장 인증

allowlist

정책 통제

Ch.4 심화

MCP 상세는 다음 장

네트워크 트러블슈팅

증상에서 원인으로

연결 타임아웃

프록시 변수 누락, 방화벽 차단

curl -v로 계층 분리

TLS 체인 오류

사내 CA 미등록

NODE_EXTRA_CA_CERTS

407 응답

프록시 인증 실패

로컬 중계 도입

스트리밍 끊김

MTU, 검사 장비 버퍼링

MTU 조정, 예외 등록

일부 기능만 실패

도메인 부분 차단

필수 도메인 표 대조

사내 MCP 불통

NO_PROXY, sandbox 누락

양쪽 목록 동시 확인

네트워크 설정 체크리스트

롤아웃 전 확인 6항

도메인 개방	필수 도메인 표 반영 확인	미러, PrivateLink 대체분 표기
프록시 배포	3변수 일괄 주입, NO_PROXY 정합	profile.d, MDM
CA 배포	PEM 번들 + OS 저장소 등록	형상 관리로 갱신
샌드박스	allowedDomains 초안 적용	curl 갭 봉쇄 검증
DLP	혹 스크립트 배포와 로그 확인	오탐 리뷰 채널
검증	각 플랫폼 1대씩 실사용 시나리오	설치, 추론, MCP 왕복

Part 4 Recap

네트워크와 보안 핵심 정리

KEY TAKEAWAY

들어오는 길은 프록시와 CA로 열고, 나가는 길은 샌드박스 도메인과 DLP 혹은로 줍니다.
권한 규칙과 샌드박스는 다른 계층입니다.

핵심 정리

1. 필수 도메인 표가 방화벽 기준선
2. 프록시 3변수 + 로컬 중계
3. 사내 CA는 EXTRA_CA_CERTS
4. sandbox로 curl 우회 갭 봉쇄
5. DLP 혹은 전송+민감 결합 판정

다음 파트

1. Part 5 거버넌스와 정책
2. managed 4채널 배포
3. 잠금 키와 병합 규칙
4. MCP, 마켓플레이스 통제
5. auto-mode 조직 구성

CHAPTER 03 / PART 05

거버넌스와 정책

개인이 못 바꾸는 것을 설계한다

1. managed settings 4채널과 우선순위
2. 병합 규칙과 잠금 키
3. MCP, 마켓플레이스, 혹은 통제
4. 조직 CLAUDE.md와 auto-mode 구성

managed settings 4채널

정책이 기기에 도달하는 네 경로 (우선순위)

1 Server-managed

claude.ai 어드민 콘솔에서 배포

전 플랫폼, Teams/Ent 전용

2 plist / HKLM

com.anthropic.claudecode, HKLM\Software\Classes\CLSID\{A509B1A7-17EE-4638-8FEE-AA001B21E622}\DefaultIcon

macOS, Windows, 변조 저항

3 파일 기반

/etc/claude-code/managed-settings.json 등

전 플랫폼, 형상 관리 배포

4 HKCU

사용자 레지스트리, 권한 상승 불필요

Windows, 편의용 (비강제)

규칙

기기에서 처음 발견되는 채널 하나 사용

/status가 소스 표기

Server-managed 상세

콘솔에서 바로, 인프라 없이

SERVER-MANAGED

인증 시점에 기기로 내려오고 활성 세션 중 매시간 갱신됩니다.

엔드포인트 인프라가 필요 없지만 Teams, Enterprise 플랜 전용입니다.

DELIVERY

도달 시점

로그인 인증 시 수신, 세션 중
시간 단위 자동 갱신.

NO INFRA

무인프라

MDM이나 파일 배포 파이프
라인 없이 콘솔에서 완결.

LIMIT

플랜 제약

Teams, Enterprise 전용,
타 공급자 사용자는 미수신.

MIX

혼합 전략

타 공급자 병행 조직은 파일,
plist 폴백을 함께 배포.

인증 시
최초 도달

매시간
갱신 주기

(remote)
/status 표기

폴백 병행
혼합 조직 공식

managed-settings.json 예시

조직 기준선 정책 한 장

●●● /etc/claude-code/managed-settings.json

```
{
  "permissions": {
    "deny": ["Read(/.env*)", "Bash(rm -rf:*)",
            "Bash(curl * | bash:*)"],
    "disableBypassPermissionsMode": "disable"
  },
  "sandbox": { "enabled": true, "network":
    { "allowedDomains": ["api.anthropic.com", "*.corp.example"] } },
  "allowedMcpServers": ["github", "corp-wiki"],
  "minimumVersion": "2.1.190",
  "env": { "CLAUDE_CODE_USE_BEDROCK": "1" }
}
```

deny 핵심

위험 최소 집합

bypass 차단

우회 모드 봉쇄

sandbox

도메인 통제 결합

env 강제

공급자 스위치

병합 규칙

managed가 이기되, 배열은 합쳐진다

MERGE SEMANTICS

스칼라 값은 managed가 사용자, 프로젝트 값을 덮습니다.

배열인 permissions.allow, deny는 전 소스가 병합되어 개발자가 확장은 해도 제거는 못 합니다.

스칼라 (덮어쓰기)

- model, minimumVersion 등 단일 값
- managed > 사용자 > 프로젝트
- 개인 설정은 조용히 무시됨
- 혼선 방지 위해 배포 공지 필요

배열 (병합)

- permissions.allow, deny
- 전 소스 엔트리가 합집합
- 개발자가 자기 allow 추가 가능
- managed deny는 누구도 제거 불가

잠금 키 일람

우회로를 닫는 스위치들

`allowManagedPermissionRulesOnly`

managed 규칙만 유효, 개인 allow 무시

고통제 환경용

`disableBypassPermissionsMode`

`--dangerously-skip` 우회 봉쇄

전사 기본 권장

`allowManagedHooksOnly`

managed 혹은 로드

혹 주입 차단

`allowedHttpHookUrls`

HTTP 혹은 목적지 허용 목록

웹훅 유출 통제

`strict/blockedMarketplaces`

플러그인 마켓 소스 통제

공급망 방어

`minimumVersion`

구버전 강제 상향

보안 픽스 하한

MCP와 마켓플레이스 통제

확장 지점의 화이트리스트

<code>allowedMcpServers</code>	승인 서버 목록, 그 외 추가 차단	사내 승인 절차 연동
<code>deniedMcpServers</code>	명시 차단 목록	사고 대응 시 즉시 배포
<code>allowManagedMcpServersOnly</code>	managed 정의 서버만 연결	최고 수준 통제
<code>strictKnownMarketplaces</code>	알려진 마켓만 추가 허용	플러그인 공급망
<code>blockedMarketplaces</code>	특정 마켓 차단	위험 소스 격리
효과 범위	서브에이전트 인라인 정의에도 적용	v2.1.153+ 일관 강제

조직 CLAUDE.md 정책

모든 세션에 실리는 지시문

MANAGED POLICY CLAUDE.MD

관리 정책 경로에 둔 CLAUDE.md는 전 세션에 로드되며 사용자가 제외할 수 없습니다.

규칙이 아니라 행동 지침을 배포하는 채널입니다.

WHERE

배치 경로

managed 설정 디렉토리,
4채널과 동일 배포.

FORCE

제외 불가

개인, 프로젝트 메모리보다
앞서 항상 로드.

WHAT

답을 내용

보안 수칙, 금지 관행, 사내
표준 링크 등 지침.

NOT

담지 않을 것

긴 문서 전문, 프로젝트별 세
부는 각 계층으로.

전 세션

적용 범위

제외 불가

강제 수준

지침 채널

규칙과의 분업

간결 유지

컨텍스트 예산

auto-mode 조직 구성

분류기에게 신뢰 경계를 알려주기

auto-mode-config

```
// managed-settings.json 발췌
{ "autoMode": {
  "trustedRepositories": ["github.corp.example/*"],
  "trustedBuckets": ["s3://corp-data-*"],
  "trustedDomains": ["*.corp.example"],
  "blockOverrides": ["Bash(aws iam *:*)"],
  "allowOverrides": ["Bash(kubectl get:*)"] } }
```

```
$ claude auto-mode show      # 유효 구성 확인
```

```
$ claude auto-mode test "aws iam create-user x"
```

```
# 분류기 판정을 배포 전에 시뮬레이션
```

신뢰 3종

repo, bucket, domain

overrides

기본 규칙 가감

show/test

CLI 서브커맨드

Ch.1 연결

Auto 모드 심화

권한 패턴 설계 전략

deny는 좁고 단단하게, allow는 넓고 명시적으로

PATTERN STRATEGY

managed deny는 논쟁 없는 위험만 최소로 고정하고, 생산성 allow는 넉넉히 명시하며, 회색 지대는 ask와 auto 분류기에 맡깁니다.

managed deny (최소, 불변)

1. 파괴 명령: `rm -rf`, 디스크 포맷류
2. 자격증명 파일 읽기: `.env`, 키 경로
3. 파이프 실행: `curl | bash` 패턴
4. IAM 변조 등 권한 상승 명령

allow와 회색 지대

1. 빌드, 테스트, 린트 명령 명시 allow
2. git 조회 계열 전면 allow
3. push, 배포는 ask로 확인 유지
4. 나머지는 auto 분류기 + 신뢰 경계

감사 후 / 조직 로그

누가 무엇을 실행했는가

audit hook (managed)

```
// managed-settings.json 발췌
{ "allowManagedHooksOnly": true,
  "hooks": { "PreToolUse": [
    { "matcher": "Bash|Write|Edit",
      "hooks": [{ "type": "command",
                  "command": "/opt/claude/audit.sh" }] } ] } }

# /opt/claude/audit.sh: stdin JSON을 요약해
#   사용자, 시각, 도구, 대상 4필드를 사내 로그로 송신
# exit 0 유지: 기록만 하고 차단하지 않음
```

3도구 매칭

Bash, Write, Edit

4필드

who, when, tool, target

exit 0

관찰 전용 원칙

OnlyManaged

혹 무결성 보장

적용 검증 / /status

정책이 정말 걸렸는지 한 줄로

~/proj \$ claude

> /status

출력 중 확인 라인

Enterprise managed settings (file)

괄호 안 소스: remote | plist | HKLM | HKCU | file

함께 확인

Provider: Bedrock (env 강제 반영 여부)

Model: 조직 기본 모델

Sandbox: enabled

파일럿 기기 전수에서 소스 표기 스크린샷 수집

한 줄 검증

managed 표기

5 소스

괄호 안 채널명

전수 확인

링별 검증 절차

Lab 1

실습 판정 기준

정책 업데이트 워크플로

정책도 코드처럼

STEP 1

PR 제안

정책 저장소에 변경
PR, 사유 기록

STEP 2

시뮬레이션

auto-mode test,
스테이징 기기 검증

STEP 3

링 배포

파일럿 링부터
채널별 배포

STEP 4

관측

차단 로그, 문의량
모니터

STEP 5

전사 확정

롤백 태그 유지,
공지

정책 저장소 + PR 리뷰 + 링 배포 = Policy as Code

PR 리뷰

변경 통제

test 명령

사전 시뮬레이션

링 순서

점진 적용

롤백 태그

즉시 복구 수단

Part 5 Recap

거버넌스와 정책 핵심 정리

KEY TAKEAWAY

채널 4개 중 하나로 도달, 배열은 병합되고 스칼라는 덮입니다.

잠금 키로 우회로를 닫고, /status 한 줄과 Policy as Code로 운영합니다.

핵심 정리

1. 4채널: remote, plist/HKLM, file, HKCU
2. 배열 병합: 확장 가능, 제거 불가
3. 잠금 키 6종으로 우회 봉쇄
4. MCP, 마켓, 혹은 CLAUDE.md 통제
5. auto-mode 신뢰 경계 + test

다음 파트

1. Part 6 모니터링과 비용
2. OTel 클라이언트 관측
3. Analytics 대시보드
4. 비용 귀속과 예산 알람
5. 이상 감지와 운영 리뷰

CHAPTER 03 / PART 06

모니터링과 비용

쓰임을 보고, 비용을 귀속시키기

1. 관측 3축: OTel, Analytics, Costs
2. 메트릭 카탈로그와 SIEM 연계
3. 사용자별 비용 귀속과 예산 알람
4. 최적화 전략과 이상 감지

관측 3축

무엇을 보고 싶은가로 고른다 (admin-setup)

Usage monitoring

OTel로 세션, 도구, 토큰 송출

전 공급자 지원

Analytics 대시보드

사용자별 지표, 기여 추적

Anthropic 경로 전용

Cost tracking

지출 한도, 사용 귀속

Anthropic 경로 전용

클라우드 경로

Cost Explorer, GCP Billing, Azure CM

과금 데이터 직접 활용

대시보드 주소

claude.ai/analytics/claude-code

Teams, Enterprise 포함

OTel 설정

관리 설정으로 전사 계측

managed env (telemetry)

```
// managed-settings.json 의 env 로 전사 배포
{ "env": {
  "CLAUDE_CODE_ENABLE_TELEMETRY": "1",
  "OTEL_METRICS_EXPORTER": "otlp",
  "OTEL_LOGS_EXPORTER": "otlp",
  "OTEL_EXPORTER_OTLP_PROTOCOL": "grpc",
  "OTEL_EXPORTER_OTLP_ENDPOINT":
    "http://otel-collector.corp.example:4317",
  "OTEL_RESOURCE_ATTRIBUTES":
    "department=platform,team=payments"
} }
```

ENABLE=1

계측 스위치

otlp/grpc

표준 송출

Collector

사내 수집 게이트

RESOURCE_ATTR

부서 태깅

메트릭 카탈로그

무엇이 계측되는가

세션	세션 수, 활성 시간	채택률 지표
토큰	입력, 출력, 캐시 읽기/생성	비용 근사 원천
비용	추정 비용 카운터	모델 단가 반영
도구	도구별 호출 수, 승인/거부	정책 마찰 신호
코드 변화	수정 라인, 커밋, PR	기여 추적
이벤트	프롬프트 제출 등 로그	SIEM 연계 소스

SIEM 연계

보안 관점의 활용

PIPE

경로

Collector에서 Splunk,
OpenSearch 등으로 분기.

JOIN

결합

파트 5 감사 로그와 사용자
키로 조인.

RULES

탐지 규칙

거부 급증, 심야 대량 토큰
, 민감 경로 접근.

CASE

대응 연결

티켓 자동 발부,
deniedMcpServers 긴급
배포.

Collector 분기

이중 송출

혹 조인

행위 상세 결합

3 규칙

탐지 출발선

긴급 정책

대응 액션

Analytics 대시보드

claude.ai/analytics/claude-code

ANALYTICS DASHBOARD

Anthropic 경로 조직은 별도 구축 없이 사용자별 지표와 기여 추적 대시보드를 바로 씁니다.
도입 성과 보고의 기본 화면입니다.

WHO

사용자별

활성 사용자, 세션, 수용률 등
개인 단위 지표.

WHAT

기여 추적

커밋, PR 기여 등 성과 관점
지표.

ZERO

무구축

콘솔 포함 기능, 파이프라인
불필요.

MIX

혼합 조직

Bedrock 병행 시 OTel 대시
보드로 보완.

포함 기능

Teams, Enterprise

사용자 단위

해상도

성과 보고

경영 보고 소스

보완 관계

OTel과 병행

클라우드 비용 가시화

Bedrock 경로의 과금 데이터

CLOUD COST

Bedrock 사용료는 AWS 청구 체계에 그대로 잡힙니다.

Cost Explorer 필터와 태그 전략으로 서비스, 부서 단위 절단이 가능합니다.

FILTER

서비스 단절

Cost Explorer에서
Bedrock 서비스, 모델 차원
필터.

TAG

태그 전략

애플리케이션 인퍼런스 프
로파일에 비용 태그 부여.

SPLIT

부서 배분

태그, 계정 분리로 차지백 리
포트 구성.

DAILY

일 단위 추적

일별 비용 그래프로 추세와
급변 감시.

Cost Explorer

기본 도구

Inference profile

태깅 단위

차지백

부서 배분

일 단위

감시 해상도

사용자별 비용 귀속

누가 얼마나 쓰는가

ATTRIBUTION

OTel의 사용자 차원과 Bedrock 호출 신원을 결합하면 개인, 팀 단위 귀속이 완성됩니다.

게이트웨이 경유라면 이미 태그가 붙어 옵니다.

OTEL

클라이언트 차원

user, 부서 리소스 속성으로
토큰, 비용 절단.

AWS

호출 신원

SSO 역할 세션 이름이
CloudTrail에 사용자 단서로.

GW

게이트웨이

apps gateway는 사용자,
그룹 태그를 기본 제공.

REPORT

월간 절단

부서, 팀, 개인 3단 리포트를
자동 생성.

user.id

OTel 차원

role session

CloudTrail 단서

기본 태그

gateway 경유 시

3단 절단

부서, 팀, 개인

예산 알람

AWS Budgets로 초과 전에 알기

aws budgets (cli)

```
$ aws budgets create-budget \
  --account-id 111122223333 \
  --budget '{ "BudgetName": "claude-code-monthly",
    "BudgetLimit": {"Amount":"5000","Unit":"USD"},
    "TimeUnit": "MONTHLY", "BudgetType": "COST",
    "CostFilters": {"Service":["Amazon Bedrock"]} }' \
  --notifications-with-subscribers '[{
    "Notification": {"NotificationType":"ACTUAL",
      "ComparisonOperator":"GREATER_THAN","Threshold":80},
    "Subscribers": [{"SubscriptionType":"SNS",
      "Address":"arn:aws:sns:...:cost-alerts"}] }']
```

80%

1차 경보 문턱

Bedrock 필터

서비스 한정

SNS

채널 연동 지정

FORECASTED

예측 경보 병행

비용 최적화 전략

품질을 지키며 내리는 여섯 손잡이

OPT 1

모델 배분

탐색은 haiku, 본대는 sonnet,
opus는 선별.

OPT 2

캐시 활용

프롬프트 캐시 적중 관리, fork의 캐시
공유.

OPT 3

컨텍스트 위생

/clear 습관, compact 임계 조정.

OPT 4

서브에이전트

고볼륨 출력 격리로 메인 토큰 절약.

OPT 5

배치 시간대

무인 작업은 야간 예약으로 피크 회피.

OPT 6

한도 계층

그룹 기본 + 개인 예외의 지출 캡.

이상 사용 감지

정상 범위를 벗어난 신호

SIG 1

토큰 급증

개인 일 사용량이 이동평균
3배 초과.

SIG 2

심야 대량

비업무 시간대 지속 호출 패턴.

SIG 3

거부 급증

정책 거부 이벤트의 단기 폭증.

SIG 4

신규 목적지

허용 밖 도메인, MCP 시도
반복.

3x MA

급증 기준 예시

시간대

행태 축

거부 이벤트

정책 마찰 축

자동 티켓

대응 연결

분기 운영 리뷰

숫자로 도는 운영 회의

채택

활성 사용자, 세션 추세

링 확산 판단

비용

부서 절단, 모델 믹스 변화

배분 정책 조정

정책

거부 상위 규칙, 문의량

완화, 강화 결정

안전

이상 신호, DLP 적중

탐지 규칙 갱신

성과

기여 지표, 만족도

경영 보고 소스

Part 6 Recap

모니터링과 비용 핵심 정리

KEY TAKEAWAY

OTel을 관리 설정으로 전사 배포하고, 태그로 귀속시키며, 예산 알람과 이상 감지로 루프를 닫습니다.
숫자가 정책의 다음 판을 결정합니다.

핵심 정리

1. 3축: OTel, Analytics, Costs
2. managed env로 전사 계측
3. 귀속: 속성 태그 + 역할 세션
4. Budgets 80% 경보 + 예측
5. 분기 리뷰 5축 템플릿

다음 파트

1. Part 7 신원, 데이터, 컴플라이언스
2. SSO, SCIM과 오프보딩
3. 학습 미사용과 ZDR
4. CloudTrail과 규제 매핑
5. 감사 대응 패키지

CHAPTER 03 / PART 07

신원, 데이터, 컴플라이언스

감사관의 질문에 답하는 체계

1. SSO, SCIM의 두 레벨과 IdP 연동
2. 오프보딩과 세션 수명
3. 학습 미사용, ZDR, 데이터 정책
4. CloudTrail과 규제 매핑

신원 통합의 두 레벨

계정 레벨과 클라우드 레벨을 구분

TWO LEVELS

SSO, SCIM, 좌석 배정은 Claude 계정 레벨에서, Bedrock 접근 권한은 클라우드 IAM 레벨에서 관리됩니다.
혼동이 가장 잦은 지점입니다.

Claude 계정 레벨

1. SSO, SCIM 프로비저닝, 좌석 배정
2. Enterprise Administrator Guide 절차
3. claude.ai 콘솔에서 관리
4. Teams, Enterprise 플랜 대상

클라우드 IAM 레벨

1. Bedrock 호출 권한과 그룹 매핑
2. Identity Center, Workforce ID, Entra
3. Permission Set이 실권한
4. gateway 경유 시 OIDC가 이 층 흡수

IdP 연동 지도

우리 IdP는 어디에 꽂히는가

IAM Identity Center

AWS 표준, Permission Set 매핑

Bedrock 경로 1순위

Okta

SAML/OIDC, Identity Center 상류로도

혼합 조직 허브

Microsoft Entra ID

Foundry 자연 결합, SCIM 지원

M365 표준 조직

Google Workspace

Workforce Identity 연계

GCP 경로

프로토콜

신규는 OIDC 권장, SAML은 기존 호환

gateway는 OIDC

그룹 매핑 전략

한 그룹 체계로 두 층을 움직인다

ONE SOURCE OF GROUPS

IdP 그룹을 단일 원천으로 삼아, 클라우드에서는 Permission Set으로, 게이트웨이에서는 모델 라우팅으로 매핑합니다.

클라우드 층 매핑

1. idp:eng-platform -> PS-Claude-Full
2. idp:eng-default -> PS-Claude-Std
3. idp:contractors -> PS-Claude-Min
4. IAM 정책 차등이 결과

게이트웨이 층 매핑

1. 동일 그룹명으로 라우팅 규칙 작성
2. opus 접근, 지출 한도 차등
3. 겸직은 상위 그룹 우선 규칙
4. 그룹 변경이 곧 권한 변경

세션과 오프보딩

떠나는 순간 접근도 끝난다

OFFBOARDING BY DESIGN

SSO 구조에서는 IdP 비활성화가 곧 접근 종료입니다. 남은 것은 세션 수명과 잔여 토큰의 시간창뿐이며, 그 창을 짧게 설계합니다.

CUT

원천 절단

IdP 계정 비활성 즉시 신규 인증 불가.

TTL

세션 수명

SSO 세션과 STS 만료를 업 무 리듬에 맞게 단축.

SWEEP

잔여 정리

setup-token 등 장기 토큰 발급 대장 기반 회수.

PROOF

증적

비활성 시각과 마지막 호출 시각의 대조 리포트.

IdP 절단

단일 지점

짧은 TTL

잔여 창 축소

토큰 대장

예외 관리

대조 리포트

감사 증적

데이터 정책

감사관의 첫 질문에 대한 답

학습 사용

Team, Enterprise, API, 클라우드 경로 미사용

공식 데이터 정책

보존

경로별 retention, 공급자 정책 상속

data-usage 문서

ZDR

요청 완료 후 무저장, Enterprise 제공

zero-data-retention

요청 단위 감사

필요 시 LLM gateway로 중앙 로깅

민감도 라우팅 포함

로컬 데이터

세션 트랜스크립트 30일 기본 정리

cleanupPeriodDays

CloudTrail 통합

Bedrock 호출의 감사 원장

cloudtrail (bedrock data events)

InvokeModel은 데이터 이벤트: 트레일에 명시 활성화 필요

```
$ aws cloudtrail put-event-selectors \  
--trail-name org-trail \  
--advanced-event-selectors '[{  
  "Name": "BedrockInvoke",  
  "FieldSelectors": [  
    {"Field": "eventCategory", "Equals": ["Data"]},  
    {"Field": "resources.type",  
      "Equals": ["AWS::Bedrock::Model"]} ] } ]'
```

기록: 시각, 주체(역할 세션), 모델 ARN, 소스 IP

Data events

명시 활성화 필요

역할 세션

사용자 귀속 필드

모델 ARN

대상 증적

S3 보존

원장 저장소

GDPR 대응

개인정보 관점의 네 질문

Q1

처리 근거

업무 도구 사용의 적법 근거
와 고지 문서화.

Q2

이전 경로

리전 선택과 데이터 경로를
계약 문서와 정렬.

Q3

보존, 삭제

ZDR 또는 retention 정책
, 로컬 정리 주기 명시.

Q4

주체 권리

로그 내 개인 식별자 대응
절차 준비.

리전

이전 통제 축

ZDR

보존 최소화 수단

고지

내부 규정 반영

legal 문서

공식 근거 페이지

SOC 2, ISO 27001 매핑

통제 항목과 구현의 대응표

접근 통제	SSO, Permission Set, 그룹 매핑	Part 2, 7
변경 관리	Policy as Code, PR 리뷰, 링 배포	Part 5
로깅, 감시	CloudTrail, OTel, 감사 로그, SIEM	Part 5, 6, 7
공급망	GPG 서명, 마켓플레이스 통제	Part 1, 5
데이터 보호	학습 미사용, ZDR, 암호화 전송	Part 7
가용성	게이트웨이 수평 확장, 버전 하한	Part 1, 3

로그 보존 정책

소스별 보존과 저장소

CloudTrail

S3 장기 보존, 조직 표준 연한

불변 저장 옵션

OTel 메트릭

백엔드 정책, 원시 90일 + 집계 장기

비용 균형

감사 로그

SIEM 인덱스, 보안 표준 연한

접근 통제 필수

로컬 트랜스크립트

cleanupPeriodDays 기본 30일

조직 표준으로 조정

게이트웨이 로그

요청 원장, 한도 판정 이력

Postgres 백업 정책

외부 감사 대응 준비

미리 싸두는 증적 패키지

AUDIT PACKAGE

감사 통지 후 모으기 시작하면 늦습니다.

분기 리뷰 산출물과 함께 증적 패키지를 상시 갱신 상태로 유지합니다.

PACK 1

정책 원본

managed-settings 이력,
PR 기록, 배포 태그.

PACK 2

적용 증명

/status 소스 표기 수집본,
링별 검증 기록.

PACK 3

행위 원장

CloudTrail, 감사 로그, SIEM
조회 절차서.

PACK 4

데이터 근거

학습 미사용, ZDR,
retention 공식 문서 스냅샷.

상시 갱신

패키지 원칙

분기 동기

리뷰와 함께

조회 절차서

감사관 셀프서비스

스냅샷

시점 고정 증거

Part 7 Recap

신원, 데이터, 컴플라이언스 핵심 정리

KEY TAKEAWAY

신원은 두 레벨로 가르고, 오프보딩은 IdP 절단으로 설계하며, 데이터는 학습 미사용과 ZDR로 답합니다.
매핑표와 증적 패키지가 감사를 짧게 만듭니다.

핵심 정리

1. 계정 레벨 vs 클라우드 레벨
2. 그룹 단일 원천, 두 층 매핑
3. IdP 절단 + 짧은 TTL
4. 학습 미사용, ZDR, CloudTrail
5. SOC2/ISO 대응표와 패키지

다음 파트

1. Part 8 트러블슈팅
2. 인증, 네트워크 진단표
3. 성능 문제 접근
4. 진단 수집 도구
5. 에스컬레이션 경로

CHAPTER 03 / PART 08

트러블슈팅

관리자에게 오는 문의의 지도

- 인증 문제 진단표
- 네트워크 문제 진단표
- 성능 문제 접근법
- 진단 수집과 에스컬레이션

인증 트러블슈팅

공식 권고 첫 세 수

로그인 루프, 계정 혼선

/logout 후 /login 재시도

공식 1순위 처방

Enterprise 옵션 안 보임

claude update 후 터미널 재시작

구버전 증상

조직 미배정 메시지

좌석에 Code 권한 미포함

어드민 콘솔에서 갱신

Bedrock 자격 실패

aws sso login 만료, 프로파일 확인

sts get-caller-identity

헬퍼 키 오류

볼트 권한, TTL 캐시 확인

스크립트 단독 실행 검증

네트워크 트러블슈팅

Part 4 진단표 요약판

타임아웃

프록시 3변수, 방화벽 도메인

curl -v 계층 분리

TLS 오류

사내 CA 미등록

NODE_EXTRA_CA_CERTS

407

인증 프록시

로컬 중계

부분 기능 실패

도메인 부분 차단

필수 도메인 표 대조

샌드박스 차단

allowedDomains 누락

정책에 도메인 추가

성능 문제 접근

느리다는 문의의 분해

PATH

경로 지연

프록시, 검사 장비 홉 측정,
리전 지연 확인.

MODEL

모델 선택

무거운 모델 기본값 여부, 작
업 대비 과사양 점검.

CONTEXT

컨텍스트 비대

긴 세션 누적, /context 확인
과 /clear 안내.

QUOTA

쿼터 스로틀

리전 TPM 한도 도달,
429 비율 관측.

홉 측정

경로 분해 시작

/context

사용자 안내 도구

429 비율

쿼터 신호

쿼터 종설

지속 시 대응

진단 수집

문의 접수 시 요청할 표준 세트

diagnostics bundle

```
$ claude doctor          # 환경 진단, f 키 자동 수정
$ claude --version

> /status                # 공급자, 모델, managed 소스
> /context               # 컨텍스트 점유 현황

$ claude --verbose 2> claude-debug.log
# 재현 후 로그 회수

# 네트워크: curl -v https://api.anthropic.com/ 결과
# 시각, 사용자, 저장소 경로를 함께 접수
```

doctor

1차 자가 진단

/status

구성 스냅샷

--verbose

재현 로그

표준 세트

접수 양식 고정

에스컬레이션 경로 / Part 8 Recap

어디까지 우리가, 어디부터 벤더가

ESCALATION

1선 헬프데스크는 진단표, 2선 플랫폼팀은 정책과 인프라, 3선은 AWS Support와 Anthropic 지원 채널입니다.

진단 번들이 각 선을 잇는 공용어입니다.

선별 기준

1. 1선: 진단표 매칭, 계정, 좌석
2. 2선: 정책, 네트워크, 게이트웨이
3. 3선 AWS: Bedrock 쿼터, 서비스 이슈
4. 3선 Anthropic: 제품 결함, 문서 괴리

Part 8 핵심

1. 재로그인, 업데이트, 좌석이 첫 세 수
2. 네트워크는 표 대조로 기계적 진단
3. 성능은 4갈래 분해
4. 진단 번들 표준화가 속도의 핵심

CHAPTER 03 / PART 09

Recap & Labs

챕터 정리와 실습 3종

1. Chapter 3 핵심 요약과 체크리스트
2. FAQ와 실습 랩 3종
3. 실행 로드맵 30/60/90
4. 학습 자료와 다음 챕터 예고

Chapter 3 핵심 요약

아홉 파트를 여섯 문장으로

DEPLOY

배포

플랫폼별 표준 조합, stable + minimumVersion, 링 롤아웃.

AUTH

자격증명

사람은 SSO, 기계는 볼트 헬퍼, CI는 OIDC, 키 배포 0.

GATEWAY

게이트웨이

SSO 로그인, 그룹 모델 라우팅, 지출 한도, OTLP.

NETWORK

네트워크

프록시, CA로 열고 sandbox 도메인 과 DLP로 좁힘.

GOVERN

거버넌스

managed 4채널, 배열 병합, 잠금 키 , Policy as Code.

OBSERVE

관측

OTel 전사 계측, 귀속 태그, 예산 알 람, 분기 리뷰.

학습 목표 체크리스트

네 가지 목표 자가 점검

SELF CHECK

네 문장에 답할 수 있으면 목표 달성입니다. 막히면 표기된 파트로 복습하세요.

CHECK 1

배포 설계

플랫폼 조합과 버전 통제
설명. (Part 1)

CHECK 2

인증 체계

SSO 흐름과 헬퍼,
게이트웨이 구성.
(Part 2, 3)

CHECK 3

정책 강제

managed 채널과 잠금
키, 병합 규칙.
(Part 4, 5)

CHECK 4

관측, 감사

OTel 배포와 귀속, 증적
패키지. (Part 6, 7)

4 Checks

목표 점검

Part 참조

복습 경로

Labs

미완은 실습으로

/status

공통 검증 도구

FAQ / 자주 나오는 질문

관리자 문의 상위 6

개인이 정책을 우회할 수 있나요

managed deny는 제거 불가, bypass 차단

Part 5 병합 규칙

Bedrock인데 서버 관리 설정이 되나요

좌석제 전용, 파일 채널 풀백

Part 5 혼합 전략

개인별 지출 캡이 되나요

apps gateway 한도 API

Part 3

코드가 학습에 쓰이나요

상업 경로 미사용, ZDR 옵션

Part 7

curl 우회는 어떻게 막나요

sandbox allowedDomains

Part 4

적용 확인은 어떻게 하나요

/status 소스 표기

Part 5

Lab 1 / managed 정책 배포

소요 15분

● ● ● LAB 1 STEPS

```
# 본 랩은 워크샵 웹사이트에서 진행합니다
$ open https://github.com/whchoi98/claude-code-workshop
  -> ccw-hands-on-lab / 해당 챕터의 랩 문서 선택
# 사전 준비물, 단계별 절차, 검증 체크리스트가 웹 문서로 제공됩니다
# 로컬에는 이 데크와 인증 환경만 준비하시면 됩니다
```

15분

예상 소요

(file)

판정 기준

deny 체험

강제 확인

제거 불가

병합 규칙 체험

Lab 2 / Bedrock SSO 전환

소요 25분

● ● ● LAB 2 STEPS

```
# 본 랩은 워크샵 웹사이트에서 진행합니다
$ open https://github.com/whchoi98/claude-code-workshop
  -> ccw-hands-on-lab / 해당 챕터의 랩 문서 선택
# 사전 준비물, 단계별 절차, 검증 체크리스트가 웹 문서로 제공됩니다
# 로컬에는 이 데크와 인증 환경만 준비하시면 됩니다
```

25분

예상 소요

caller-identity

신원 검증

Provider 표기

판정 기준

정적 키 ID

달성 상태

Lab 3 / OTel 관측 배선

소요 20분

● ● ● LAB 3 STEPS

```
# 본 랩은 워크샵 웹사이트에서 진행합니다
$ open https://github.com/whchoi98/claude-code-workshop
  -> ccw-hands-on-lab / 해당 챕터의 랩 문서 선택
# 사전 준비물, 단계별 절차, 검증 체크리스트가 웹 문서로 제공됩니다
# 로컬에는 이 데크와 인증 환경만 준비하시면 됩니다
```

20분

예상 소요

compose

컬렉터 제공

4317

OTLP 수신

메트릭 확인

판정 기준

실행 로드맵 30 / 60 / 90

도입 첫 분기의 마일스톤

DAY 0-30

기반

공급자 확정, 파일럿 링, 정책 초판

DAY 31-60

통제

managed 전 채널, 샌드박스, OTel

DAY 61-90

규모화

전사 링, 게이트웨이, 분기 리뷰 1회차

각 구간 말미에 /status 전수 검증과 경영 보고를 고정 이벤트로

30일

파일럿 가동

60일

통제 완성

90일

전사 규모화

분기 리뷰

운영 루프 시작

추가 학습 자료

이 챕터 다음에 읽을 것들

Admin setup

code.claude.com/docs/ko/admin-setup

본 텍스트의 뼈대 문서

Server-managed

docs 내 server-managed-settings

콘솔 배포 상세

apps gateway

claude-apps-gateway 문서군 5편

구성, 배포, 한도

Monitoring

monitoring-usage, analytics, costs

관측 3축 상세

Security

security, data-usage, zero-data-retention

감사 근거 문서

워크샵 코드

github.com/whchoi98/claude-code-workshop

본 과정 실습 자료

Next / Chapter 4 예고

Settings Deep Dive

CHAPTER 4 PREVIEW

오늘 강제한 정책의 반대편, 개발자가 다듬는 설정의 세계입니다. settings.json 전 키와 Permissions, Hooks, MCP 구성을 심화합니다.

NEXT 1

Settings 전 키

파일 위치, 우선순위, env 블록의 완전 지도.

NEXT 2

Permissions

규칙 문법과 모드, 조직 정책과의 상호작용.

NEXT 3

Hooks

이벤트 전 종류와 실전 레시피.

NEXT 4

MCP

서버 구성, 인증, 도구 검색과 스코프.

Ch.4
Settings

Day 2
워크샵 일정

개발자 관점
시선 복귀

To be continued
다음 세션에서

References

본 챕터 공식 문서 출처 (code.claude.com)

Admin setup	docs/ko/admin-setup	전체 프레임워크
Settings	docs/ko/settings , server-managed-settings	Part 5
Providers	amazon-bedrock , claude-platform-on-aws 등	Part 2
apps gateway	claude-apps-gateway + config, deploy, limits	Part 3
Network, Sandbox	network-config , sandboxing	Part 4
Observability	monitoring-usage , analytics , costs	Part 6

Thank you!

Choi, WooHyung / Prin. Solutions Architect, AWS Korea

whchoi@amazon.com | linkedin.com/in/woohyungchoi

Workshop code: github.com/whchoi98/claude-code-workshop